

ETSI EN 319 401 General Policy Requirements

Goya Ledger Trust Service Provider

Field	Value
Document ID	GOYA-TSP-POL-001
Version	1.1
Status	Ready for Review
Date	2026-08-31
Owner	Security Officer
Classification	Public
Normative basis	ETSI EN 319 401 V3.2.1 (2026-01), NIS2 (EU 2022/2555), CIR 2025/2160

Disclaimer: This document is a self-assessment mapping Goya Ledger’s technical and organizational controls to ETSI EN 319 401 requirements. It is not a certification, conformity assessment, or audit result. No conformity assessment body (CAB) has validated these claims. Organizations seeking qualified trust service status must engage an accredited CAB under Regulation (EU) No 910/2014, Article 20.

1. Scope

This policy defines the general requirements for the practices and procedures of Goya Ledger operating as a Trust Service Provider (TSP) under Regulation (EU) No 910/2014 (eIDAS). It applies to all trust services offered by Goya Ledger, specifically:

Trust service	Standard	Description
Certificate Authority (CA)	ETSI EN 319 411-1/2	Issuance and management of X.509 certificates via CaHierarchy (root CA offline, intermediate CA operational)
Time-Stamp Authority (TSA)	ETSI EN 319 421, RFC 3161	

Trust service	Standard	Description
		DER-encoded time-stamp tokens with NTP-enforced clock via <code>NtpTimeSource</code>
OCSP Responder	RFC 6960	Real-time certificate status via <code>src/msp/ocsp.rs</code>
Registration Authority (RA)	ETSI EN 319 411-1 clause 6.2	Identity proofing with RUT validation and biometric evidence (ISO 19794-2)
Electronic Signature Services	ETSI EN 319 142 (CAAdES)	Simple (FES/Ed25519), Advanced (FEA/ML-DSA-65), and Qualified (reserved) electronic signatures
Electronic Seal Services	ETSI EN 319 521	Organizational seals for legal persons via <code>SignatureLevel::Seal</code>

This policy covers classical and post-quantum cryptographic operations. Goya Ledger deploys ML-DSA-65 (FIPS 204) alongside Ed25519, making all trust services PQC-ready as recommended by ENISA and the French ANSSI.

Geographic applicability: Services operate under Chilean law (Ley 19.799, Decreto Supremo 24/181) with alignment to EU eIDAS requirements for cross-border recognition. Deployment infrastructure is located in Chile (primary, Santiago) with geographic distribution per the Business Continuity plan (GOYA-PS03-001).

2. References

2.1 Normative references

Reference	Title
ETSI EN 319 401 V3.2.1 (2026-01)	General Policy Requirements for Trust Service Providers
ETSI EN 319 411-1	Policy and security requirements for TSPs issuing certificates – Part 1: General requirements
ETSI EN 319 411-2	Policy and security requirements for TSPs issuing certificates – Part 2: Requirements for TSPs issuing EU qualified certificates

Reference	Title
ETSI EN 319 421	Policy and Security Requirements for Trust Service Providers issuing Time-Stamps
ETSI EN 319 142-1	CAdES digital signatures
ETSI EN 319 521	Policy and security requirements for electronic registered delivery services
ETSI TS 119 312	Cryptographic Suites for Secure Electronic Signatures
Regulation (EU) No 910/2014	eIDAS – electronic identification and trust services
Regulation (EU) 2024/1183	eIDAS 2.0 – European Digital Identity framework
FIPS 180-4	Secure Hash Standard (SHA-256)
FIPS 204	Module-Lattice-Based Digital Signature Standard (ML-DSA)
RFC 3161	Internet X.509 PKI Time-Stamp Protocol (TSP)
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	X.509 Internet PKI Online Certificate Status Protocol – OCSP
RFC 8032	Edwards-Curve Digital Signature Algorithm (EdDSA)
ISO/IEC 27001:2022	Information security management systems
ISO 19794-2	Biometric data interchange – Finger minutiae data

2.2 Chilean normative references

Reference	Title
Ley 19.799	Sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion
Decreto Supremo No 24	Reglamento de la Ley 19.799
Decreto Supremo No 181	Reglamento tecnico para PSC acreditados

2.3 Informative references

Reference	Title
NIST SP 800-57 Part 1 Rev. 5	Recommendation for Key Management
NIST SP 800-208	Recommendation for Stateful Hash-Based Signature Schemes
ENISA	Post-Quantum Cryptography: Current State and Quantum Mitigation
SOC 2	Trust Services Criteria (AICPA)

3. Definitions and abbreviations

3.1 Definitions

Term	Definition
Trust service	An electronic service consisting of the creation, verification, and validation of electronic signatures, seals, time stamps, certificates, or related services, as defined in eIDAS Art. 3(16)
Trust Service Provider (TSP)	A natural or legal person who provides one or more trust services, as defined in eIDAS Art. 3(19)
Qualified Trust Service Provider (QTSP)	A TSP that provides one or more qualified trust services and is granted the qualified status by the supervisory body, as defined in eIDAS Art. 3(20)
Relying party	A natural or legal person that relies upon an electronic identification or a trust service
Subscriber	An entity whose identity has been verified by the RA and to whom a certificate or signing credential has been issued
Registration Authority (RA)	The entity responsible for identifying and authenticating subscribers before certificate issuance
Certification Practice Statement (CPS)	A statement of the practices that a CA employs in issuing, managing, revoking, and renewing certificates
Certificate Policy (CP)	A named set of rules indicating the applicability of a certificate to a particular community or class of application
Cryptographic module	The bounded set of hardware, software, and firmware implementing approved security

Term	Definition
	functions, as defined by the FIPS 140-3 boundary in <code>src/identity/signing.rs</code>
Key ceremony	A formal, witnessed procedure for generating, distributing, and activating CA signing keys under dual control
FES (Firma Electronica Simple)	Simple electronic signature under Ley 19.799 Art. 2, implemented via <code>SignatureLevel::Simple</code> with Ed25519
FEA (Firma Electronica Avanzada)	Advanced electronic signature under Ley 19.799 Art. 2, implemented via <code>SignatureLevel::Advanced</code> with ML-DSA-65 and biometric binding

3.2 Abbreviations

Abbreviation	Expansion
AES	Advanced Encryption Standard
BFT	Byzantine Fault Tolerance
CA	Certification Authority
CAdES	CMS Advanced Electronic Signatures
CP	Certificate Policy
CPS	Certification Practice Statement
CRL	Certificate Revocation List
CSPRNG	Cryptographically Secure Pseudo-Random Number Generator
DID	Decentralized Identifier
DPoS	Delegated Proof of Stake
HSM	Hardware Security Module
KAT	Known Answer Test
ML-DSA	Module-Lattice-Based Digital Signature Algorithm
mTLS	Mutual Transport Layer Security
NTP	Network Time Protocol
OCSP	Online Certificate Status Protocol
PQC	Post-Quantum Cryptography
PSC	Prestador de Servicios de Certificacion
QTSP	Qualified Trust Service Provider
RA	Registration Authority
RPO	Recovery Point Objective
RTO	Recovery Time Objective
RUT	Rol Unico Tributario (Chilean taxpayer ID)
TSA	Time-Stamp Authority
TSP	Trust Service Provider

Abbreviation	Expansion
TSL	Trusted Service (Status) List
WAL	Write-Ahead Log

4. General concepts

4.1 Trust service lifecycle

Goya Ledger operates a trust service lifecycle conforming to ETSI EN 319 401 clause 5. The lifecycle encompasses:

1. **Service definition** – Published CP and CPS accessible via GET /policy/cp and GET /policy/cps API endpoints, and at a public URL following accreditation.
2. **Service instantiation** – Deployment of CA hierarchy, TSA, OCSP responder, and RA services on hardened infrastructure with HSM-backed key material.
3. **Service operation** – Continuous delivery of trust services under the controls defined in this policy, monitored via Prometheus metrics and health endpoints.
4. **Service monitoring** – Real-time monitoring of service availability (OCSP RTO: 15 min, TSA RTO: 4 hours), cryptographic health via power-up Known Answer Tests, and audit trail integrity via `verify_audit_chain()`.
5. **Service termination** – Orderly cessation per section 5.11 of this document.

4.2 Trust service components

The Goya Ledger TSP architecture comprises:

Component	Implementation	Security boundary
Cryptographic module	SigningProvider trait: SoftwareSigningProvider (Ed25519), MlDsaSigningProvider (ML-DSA-65), RsaSigningProvider (RSA), HsmSigningProvider (PKCS#11)	FIPS 140-3 module boundary at <code>src/identity/signing.rs</code>
CA engine	CaHierarchy with offline root CA and operational intermediate CA	<code>src/pki.rs</code> , key material in HSM
TSA engine	RFC 3161 DER-encoded tokens with monotonic serial counter and NTP enforcement	<code>src/tsa.rs</code>
OCSP responder	RFC 6960 compliant, delegated responder certificate	<code>src/msp/ocsp.rs</code>

Component	Implementation	Security boundary
RA module	Identity proofing with RUT validation, biometric evidence (ISO 19794-2 fingerprint minutiae as SHA-256 commitments)	src/identity/, RA officer accounts
Audit subsystem	Append-only hash-chained log with SHA-256, 7-year retention, JSON export	src/audit.rs
API gateway	Actix-Web 4 with mTLS, rate limiting, ACL enforcement	src/api/
Consensus layer	DAG + HotStuff BFT + DPoS for tamper-evident block ordering	src/consensus/
Storage layer	RocksDB (production) with WAL and checkpoints; memory store (testing only)	src/storage/

4.3 Levels of assurance

Assurance level	Signature type	Algorithm	Biometric	Certificate basis
Basic	FES (Simple)	Ed25519 (RFC 8032)	Optional	Self-issued DID credential
Substantial	FEA (Advanced)	ML-DSA-65 (FIPS 204)	Required (≥ 1 evidence)	RA-verified certificate from intermediate CA
High	Qualified	ML-DSA-65 (FIPS 204)	Required	QTSP-issued certificate via QSCD. Not offered until QTSP status is granted by the supervisory body (target: 2027-Q4). Requires QSCD hardware (Gap 10) and conformity assessment (Gap 11) per EU-COMPLIANCE-GAPS.md

5. TSP practices

5.1 Risk assessment

ETSI EN 319 401, clause 6.3

5.1.1 Risk assessment methodology

Goya Ledger conducts risk assessments following ISO 27005 methodology applied to all trust service components. The risk register addresses:

- **Threat categories:** Compromise of CA private keys, unauthorized certificate issuance, TSA time-source manipulation, OCSP responder denial of service, audit log tampering, subscriber identity fraud, quantum computing threats to classical cryptography, insider threats to key material.
- **Asset inventory:** All assets classified per section 5.3. Each asset assigned an owner, a confidentiality/integrity/availability rating, and a maximum tolerable downtime.
- **Risk evaluation:** Likelihood x impact matrix, with residual risk accepted only by the Security Officer.

5.1.2 Risk treatment

Risk	Treatment	Control
CA key compromise	Mitigation	HSM (FIPS 140-3 Level 3) + M-of-N custodian key ceremony + offline root CA
Quantum threat to Ed25519 signatures	Mitigation	ML-DSA-65 (FIPS 204, Level 3 security) deployed alongside Ed25519; hybrid migration path documented
Unauthorized certificate issuance	Mitigation	RA identity proofing (RUT + biometric) + dual-approval workflow + audit log
TSA time manipulation	Mitigation	NTP enforcement via <code>NtpTimeSource::validate()</code> with configurable maximum drift; monotonic serial counter persisted to storage
Audit log tampering	Mitigation	SHA-256 hash chain with each entry referencing the previous entry's hash; append-only storage; integrity verification via <code>verify_audit_chain()</code>
Single point of failure	Mitigation	BFT consensus (tolerates $f < n/3$ Byzantine nodes); geographic distribution (Santiago primary, backup site); Raft log replication

Risk	Treatment	Control
Insider threat	Mitigation	Dual-person rule for Tier 1 access; M-of-N key activation; segregation of duties between RA officer, PKI administrator, and Security Officer

5.1.3 Review frequency

Risk assessments are reviewed: - Annually, as part of the management review cycle. - After any P1 or P2 security incident (see GOYA-PS07-001). - Upon introduction of new trust services, algorithms, or significant infrastructure changes. - When NIST, ENISA, or ANSSI issue new advisories affecting deployed algorithms.

5.2 Policies and practices

ETSI EN 319 401, clause 6.2

5.2.1 Certificate Policy (CP) and Certification Practice Statement (CPS)

The CP and CPS are maintained as structured documents in the codebase (`src/pki_policy.rs`) and published via the API:

Document	Endpoint	Format
Certificate Policy	GET /policy/cp	JSON / Markdown
Certification Practice Statement	GET /policy/cps	JSON / Markdown

The CP defines: - Certificate profiles for subscriber, intermediate CA, and OSCP delegated responder certificates. - Naming conventions: `did:goya:{pubkey_hex[..16]}` as the subject identifier, derived canonically via `identity::did::did_from_pubkey_hex()`. - Key usage constraints per certificate type. - Validity periods and renewal procedures. - Revocation policy and CRL issuance schedule.

The CPS describes operational procedures for: - RA identity proofing (RUT verification, biometric evidence collection). - Key generation and ceremony procedures. - Certificate issuance, suspension, and revocation workflows. - HSM operations and key lifecycle management.

5.2.2 Policy approval and publication

- CP and CPS amendments require approval by the Security Officer.
- Changes are version-controlled in git with signed commits.
- Subscribers are notified of material CP/CPS changes at least 30 days in advance.
- The authoritative CPS URL is published in the `cPSuri` qualifier of all issued certificates.

5.2.3 Internal policies

Policy document	Document ID	Scope
Information Security Policy	GOYA-PS02-001	Organization-wide security governance (docs/compliance/PS02-SECURITY-POLICY.md)
Incident Response Plan	GOYA-PS07-001	Security incident detection, triage, containment, recovery (docs/compliance/PS07-INCIDENT-MANAGEMENT.md)
Business Continuity Plan	GOYA-PS03-001	Service continuity and disaster recovery (docs/compliance/PS03-BUSINESS-CONTINUITY.md)
Physical Security Policy	GOYA-SF01-001	Facility access, environmental controls, HSM protection (docs/compliance/SF01-PHYSICAL-SECURITY.md)
Key Management Policy	GOYA-PS06-001	Key generation, storage, zeroization, ceremony (docs/compliance/PS06-KEY-MANAGEMENT-PLAN.md)
Acceptable Use Policy	GOYA-AUP-001	Personnel use of TSP systems and data (docs/policy/ACCEPTABLE-USE-POLICY.md)
Cross-Certification Strategy	GOYA-XCERT-001	Trust chain extension and cross-certification (docs/compliance/CROSS-CERTIFICATION.md)

5.3 Asset management

ETSI EN 319 401, clause 7.4.3

5.3.1 Asset classification

Asset class	Examples	Classification	Owner
CA private keys	Root CA key, intermediate CA key	Confidential – Critical	PKI Administrator
TSA signing key	Time-stamp token signing key	Confidential – Critical	PKI Administrator
OCSP responder key	Delegated responder signing key	Confidential – High	PKI Administrator
Subscriber private keys	FES (Ed25519) and FEA (ML-DSA-65) keys generated client-side	Confidential – High (subscriber responsibility)	Subscriber
Certificate database	Issued certificates, CRLs, OCSP responses	Integrity – Critical	System Administrator
Audit log	Hash-chained audit entries, 7-year retention	Integrity – Critical	Security Officer
Blockchain state	Block ledger, Raft log, world state in RocksDB	Integrity – Critical	System Administrator
Source code	Application source, configuration, deployment scripts	Integrity – High	Development Lead
HSM devices	PKCS#11 hardware (Thales Luna / Entrust nShield)	Physical – Critical	Security Officer
TLS certificates	Server and client mTLS certificates	Confidential – High	System Administrator
Backup media	RocksDB snapshots, checkpoint exports	Confidential – High	Operations Lead
Biometric commitments	SHA-256 hashes of ISO	Integrity – High	RA Officer

Asset class	Examples	Classification	Owner
	19794-2 minutiae (no raw biometric data)		

5.3.2 Asset handling

- All assets classified as Critical require dual-person access.
- Private key material is never stored in plaintext outside an HSM or a process with ZeroizeOnDrop semantics.
- Backup media is encrypted at the filesystem level (LUKS on Linux, FileVault on macOS; see docs/compliance/ENCRYPTION-AT-REST.md).
- Asset decommissioning follows NIST SP 800-88 guidelines for media sanitization.

5.4 Access control

ETSI EN 319 401, clause 7.4.4

5.4.1 Role-based access control

Role	Permissions	Authentication	Segregation
Security Officer	Policy approval, incident response lead, access list management, risk acceptance	mTLS client certificate + multi-factor	Cannot perform PKI operations
PKI Administrator	CA operations, certificate issuance/revocation, CRL publication, HSM operations	mTLS client certificate + HSM PIN	Cannot approve policy changes
RA Officer	Identity proofing, certificate request approval/rejection	mTLS client certificate + biometric	Cannot directly issue certificates
System Administrator	Infrastructure management, deployment, monitoring	mTLS client certificate + SSH key	Cannot access key material
Auditor	Read-only access to audit logs, metrics, compliance reports	mTLS client certificate	No write access to any system
Operator		mTLS client certificate	No access to signing keys

Role	Permissions	Authentication	Segregation
	Node operations via <code>bcctl.sh</code> , health monitoring		

5.4.2 System access controls

- **Default deny:** ACL mode enforced via `enforce_acl()` middleware. The `ACL_MODE` environment variable must be set to `strict` in production; permissive mode triggers a warning on startup.
- **Authentication:** All API access requires mTLS or JWT. JWT signing secret is a required environment variable (`JWT_SECRET`); the node refuses to start if it is missing or matches the default.
- **Session management:** JWT tokens with configurable expiry. No session state stored server-side.
- **Privileged access:** Admin role inferred from X.509 CN attributes in the client certificate chain. Admin operations logged with `AuditAction::SecurityOfficerLogin`.
- **Account lifecycle:** Access revoked within 24 hours of role change or personnel departure (Tier 2 requirement per GOYA-SF01-001).

5.4.3 Network access controls

- All P2P communication over mutual TLS (rustls, TLS 1.3 minimum).
- API endpoints scoped under `/api/v1` via `ApiRoutes::register`.
- CORS restricted to configured origins (`CORS_ALLOWED_ORIGINS`).
- Rate limiting enforced at three levels: per-second (`RATE_LIMIT_RPS`), per-minute (`RATE_LIMIT_RPM`), per-hour (`RATE_LIMIT_RPH`).
- Management network physically separated from service network in Tier 2 facilities.

5.5 Cryptographic controls

ETSI EN 319 401, clause 7.4.6; ETSI TS 119 312

5.5.1 Approved algorithms

All cryptographic operations are confined to the FIPS 140-3 module boundary (`src/identity/signing.rs`). Direct imports of `sha2`, `ed25519_dalek`, `pqcrypto_mldsa`, or `rsa` outside the `pq_crypto_module` crate are prohibited and enforced by `cargo test --test crypto_boundary`.

Algorithm	Standard	Purpose	Implementation	Key size
Ed25519	RFC 8032	Digital signatures (classical)	ed25519-dalek 2.1 via <code>SoftwareSigningProvider</code>	256-bit private, 256-bit public
ML-DSA-65	FIPS 204	Digital signatures (post-quantum, NIST Level 3)	pqcrypto-mldsa via <code>MldsaSigningProvider</code>	4032-byte private, 1952-byte public,

Algorithm	Standard	Purpose	Implementation	Key size
				3309-byte signature
RSA	PKCS#1 v2.2	Digital signatures (legacy interoperability)	rsa crate via RsaSigningProvider	$\geq$ 3072-bit
SHA-256	FIPS 180-4	Hashing (blocks, Merkle roots, audit chain, biometric commitments)	sha2 0.10	256-bit digest
SHA3-256	FIPS 202	Hashing (alternative, protocol diversity)	sha3 crate	256-bit digest
HMAC-SHA256	FIPS 198-1 / RFC 2104	Message authentication (oracle reports)	hmac 0.12	256-bit key
AES-256-GCM	FIPS 197 / SP 800-38D	Key encryption (client-side key protection)	Via Argon2id KDF + AES-256-GCM	256-bit
Argon2id	RFC 9106	Key derivation (subscriber key encryption)	Client-side	Configurable cost parameters

5.5.2 Algorithm deprecation and migration

- Ed25519 remains approved for FES (Simple) signatures where post-quantum resistance is not required.
- New FEA (Advanced) and Qualified signatures default to ML-DSA-65.
- RSA is available for legacy interoperability only; new deployments should not select RSA as the primary algorithm.
- The `SIGNING_ALGORITHM` environment variable selects the active signing provider at node startup.
- Algorithm agility is achieved through the `SigningProvider` trait with `Vec<u8>` signatures, supporting Ed25519 (64 bytes), ML-DSA-65 (3309 bytes), and RSA (variable) without protocol changes.
- Every signed structure carries `signature_algorithm: SigningAlgorithm` with `#[serde(default)]` for forward compatibility.

5.5.3 Cryptographic self-tests

`run_crypto_self_tests()` executes at node startup before any external data is processed. The node refuses to start if any test fails.

Test	Algorithm	Procedure
KAT – sign/verify positive	Ed25519	

Test	Algorithm	Procedure
KAT – sign/ verify negative	Ed25519	Generate key, sign "FIPS-140-3-KAT-Ed25519", verify succeeds Corrupt one byte of signature, verify rejected
KAT – sign/ verify positive	ML-DSA-65	Generate key, sign "FIPS-140-3-KAT-ML-DSA-65", verify succeeds
KAT – sign/ verify negative	ML-DSA-65	Corrupt one byte of signature, verify rejected
KAT – hash	SHA-256	Hash known input, compare against NIST test vector

5.5.4 Key management

Key generation: - Ed25519: `SigningKey::generate(&mut OsRng)` – 32 bytes from OS CSPRNG (`getrandom`). - ML-DSA-65: `pqcrypto_mldsa::mldsa65::keypair()` – internal CSPRNG from PQClean reference implementation. - CA keys: Generated during formal key ceremony (`KeyCeremony` in `src/pki_ceremony.rs`) with M-of-N custodian shares, minimum 2 witnesses, 1 notary. Video-recorded with notarized minutes.

Key storage: - CA root key: Offline, stored in HSM (FIPS 140-3 Level 3) in Tier 1 facility. Never connected to any network. - CA intermediate key: Operational HSM in Tier 2 facility. Accessible via PKCS#11 (`HsmSigningProvider`). - TSA/OCSP keys: HSM-backed in production. Software provider permitted for development/staging only. - Subscriber keys: Generated client-side, never transmitted. Encrypted with Argon2id + AES-256-GCM at rest on client device.

Key zeroization: - `SoftwareSigningProvider: ed25519_dalek::SigningKey` implements `ZeroizeOnDrop` – automatic on drop. - `MLDsaSigningProvider`: Custom `Drop` replaces secret key with fresh keypair (opaque C struct; direct zeroization not possible). - HSM keys: Zeroization delegated to HSM hardware (FIPS 140-3 Level 3 tamper-response).

Key lifecycle: - One signing key per node lifetime. Key rotation requires node restart. - CA key lifetime: Root CA – 20 years; Intermediate CA – 5 years; Subscriber – 1-3 years (per CP). - No key escrow. Subscriber private keys are never held by the TSP.

5.5.5 HSM requirements

Requirement	Standard	Implementation
FIPS 140-3 Level 3 validation	FIPS 140-3	Thales Luna Network HSM 7 or Entrust nShield Connect
PKCS#11 interface	OASIS PKCS#11 v2.40+ CKM_EDDSA	<code>HsmSigningProvider</code> via <code>cryptoki</code> crate, feature-gated (<code>--features hsm</code>)

Requirement	Standard	Implementation
EdDSA mechanism support		Verified with vendor prior to procurement
Tamper-evident casing	FIPS 140-3 Level 2+	HSM vendor specification
Zeroization on tamper	FIPS 140-3 Level 3	Hardware feature
Dual-operator activation	M-of-N custody	CeremonyConfig.threshold

5.6 Physical and environmental security

ETSI EN 319 401, clause 7.4.5

Physical security controls are defined in full in GOYA-SF01-001. Summary:

5.6.1 Facility tiers

Tier	Facility	Access control	Environmental
Tier 1 – High Security	Root CA, key ceremony room, HSM vault	Biometric + PIN + physical key; two-person rule; quarterly access review	18-24 C, 40-60% RH, FM-200 suppression, UPS + generator, TEMPEST-aware, CCTV 90-day retention
Tier 2 – Operational	Intermediate CA, TSA, OCSP, API servers	Badge + PIN; visitor escort; 24h revocation on role change	18-27 C, redundant power, fire detection, physically separated management network
Tier 3 – Support	Development, staging, monitoring	Standard badge access	No production keys; simulated HSM (SimulatedHsmProvider)

5.6.2 Key ceremony room

- Air-gapped: no network connectivity.
- Faraday cage or RF-shielded enclosure.
- Dedicated ceremony equipment never connected to any network.
- Witness seating with clear sightlines to all operations.
- Secure storage for ceremony records and custodian key shares.
- All ceremonies video-recorded and notarized.

5.7 Operations security

ETSI EN 319 401, clause 7.4.7

5.7.1 Change management

- All source changes tracked in git with code review (pull request workflow).

- Pre-commit quality gate: `cargo fmt --check`, `cargo clippy -- -D warnings`, `cargo test --lib`.
- Integration tests executed when integration test files are modified.
- Deployment via Docker Compose (`docker compose up -d`) with version-pinned images.
- Rollback via checkpoint restore (`src/checkpoint.rs`, `src/storage/snapshot.rs`).

5.7.2 Capacity management

- Configurable mempool size (`MEMPOOL_MAX_SIZE`).
- P2P buffer sizes configurable per deployment.
- Rate limiting at API layer (RPS/RPM/RPH).
- Health endpoint (`/health`) with dependency verification (storage, consensus, NTP).
- Prometheus metrics and Grafana dashboards for real-time capacity monitoring.

5.7.3 System hardening

- Production mode (`RUST_BC_ENV=production`) enforces:
 - Mandatory `TLS_CERT_PATH` and `TLS_KEY_PATH`.
 - Warning on `ACL_MODE=permissive`.
 - Audit log persistence to RocksDB.
- Nightly Rust toolchain (`rust-toolchain.toml`) with all compiler warnings treated as errors via `cargo clippy -- -D warnings`.
- No arbitrary code execution: chaincode runs in Wasm sandbox (Wasmtime).
- Secure Boot and measured boot required for Tier 2 servers.

5.7.4 Backup and restore

- **Blockchain state:** Replicated across consensus nodes (BFT, tolerates $f < n/3$).
- **Audit logs:** Append-only with SHA-256 hash chain; RocksDB WAL + periodic checkpoints.
- **Checkpoints:** Every 1000 blocks or 1 hour (whichever occurs first) via `src/checkpoint.rs`.
- **RocksDB snapshots:** Export/import via `src/storage/snapshot.rs`.
- **Raft log:** Persistent via `src/ordering/raft_storage.rs`.
- **CA keys:** M-of-N custodian shares stored in geographically distributed Tier 1 vaults.
- **Certificates/CRL:** Reproducible from CA key + serial state.

5.7.5 Logging and monitoring

Log type	Mechanism	Retention	Tamper evidence
Audit log	AuditStore trait, append-only, hash-chained (SHA-256)	7 years, auto-purge after retention period	Each entry contains <code>previous_hash</code> ; integrity verified by <code>verify_audit_chain()</code>
API access log	Actix middleware, structured JSON (<code>LOG_FORMAT=json</code>)	Per deployment policy	Correlated via trace ID in <code>ApiResponse<T></code>

Log type	Mechanism	Retention	Tamper evidence
System metrics	Prometheus counters and gauges	Per Prometheus retention configuration	N/A (operational, not evidentiary)
Security events	Audit log with AuditAction variants (e.g., SecurityOfficerLogin, certificate issuance, revocation)	7 years	Hash-chained

5.8 Network security

ETSI EN 319 401, clause 7.4.8

5.8.1 Transport security

Channel	Protocol	Configuration
API (client-to-server)	TLS 1.3 via rustls	Server certificate + optional client certificate (mTLS); OCSP stapling; certificate pinning
P2P (node-to-node)	Mutual TLS 1.3 via rustls	Both peers authenticate; gossip messages carry signatures verified on receipt
Management	SSH + mTLS	Physically separated management network (Tier 2); console access requires physical presence

5.8.2 Network architecture

- API gateway serves all endpoints under /api/v1.
- P2P network on dedicated port (P2P_PORT, default 8081), separate from API port (API_PORT, default 8080).
- Light client mode (NODE_MODE=light) proxies via SeedProxy to full node; does not participate in consensus.
- CORS restricted to CORS_ALLOWED_ORIGINS.
- HTTP request timeout configurable via HTTP_REQUEST_TIMEOUT_SECS.

5.8.3 Network message integrity

P2P protocol messages are signed and verified at the gossip layer. Message flow:

1. SubmitTransaction – signed by submitting node.
2. OrderedBlock – signed by ordering node after BFT consensus.
3. StateRequest / StateResponse – authenticated via mTLS channel.
4. Push-gossip block propagation with signature verification on receipt.

5.9 Incident management

ETSI EN 319 401, clause 7.4.8

Incident management is defined in full in GOYA-PS07-001. Summary:

5.9.1 Severity classification

Level	Description	Response time	Escalation
P1 – Critical	CA key compromise, mass certificate mis-issuance	< 1 hour	Security Officer + CEO + Supervisory Body
P2 – High	TSA/OCSP outage > 1 hour, single certificate mis-issuance	< 4 hours	Security Officer + CTO
P3 – Medium	Audit log integrity failure, RA process violation	< 24 hours	Security Officer
P4 – Low	Failed login attempts, minor policy deviation	< 72 hours	Operations team

5.9.2 Notification obligations

- **eIDAS Art. 19(2):** The TSP shall notify the supervisory body of any breach of security or loss of integrity that has a significant impact on the trust service, without undue delay but within 24 hours.
- **Ley 19.799:** Notify the Entidad Acreditadora (Subsecretaria de Economia) for P1 incidents.
- **Subscribers:** Notify affected subscribers of any incident impacting the validity or trustworthiness of their certificates or signatures.

5.9.3 Incident response procedures

1. **Detection:** Automated monitoring (audit log alerts, health checks, `verify_audit_chain()`) or manual reporting to `security@goya.cl`.
2. **Triage:** Security Officer assigns severity (P1-P4) and incident ID (INC-YYYY-NNNN).
3. **Containment:** Per severity – P1: immediate CRL publication, OCSP suspension for compromised CA, activation of backup CA from custodian shares. P2: failover to backup infrastructure. P3: suspend affected RA officer account, quarantine records.
4. **Eradication:** Root cause analysis via forensic analysis (`src/forensic.rs`), vulnerability patching, system rebuild from known-good state.
5. **Recovery:** Services restored in order: CA, CRL, OCSP, TSA, RA. Audit chain integrity verified. NTP synchronization confirmed.
6. **Post-incident:** Report within 7 days, root cause analysis, plan update, stakeholder brief, regulatory notification if required.

5.10 Business continuity

ETSI EN 319 401, clause 7.4.9

Business continuity is defined in full in GOYA-PS03-001. Summary:

5.10.1 Recovery objectives

Service	RTO	RPO	Justification
OCSP Responder	15 minutes	0 (stateless)	Certificate validation must not stall relying parties
CRL Publication	1 hour	Last CRL	Revocation information must remain timely
API Gateway	15 minutes	N/A	Subscriber access to all services
Audit Log	4 hours	0 (hash chain)	Regulatory requirement for tamper-evident records
TSA	4 hours	Last token serial	Timestamp continuity requires serial monotonicity
CA (issuance)	24 hours	Last issued certificate	New certificates can queue; revocation cannot wait
RA (proofing)	48 hours	Last proofing record	Human process; requests can queue

5.10.2 Resilience architecture

- **Consensus replication:** BFT consensus (HotStuff) tolerates $f < n/3$ Byzantine faults. Single node failure recovers in < 1 minute via automatic Raft failover.
- **Geographic distribution:** Primary (Santiago), secondary (standby: OCSP, CRL mirror, read-only API), offline vault (root CA key shares, backup media).
- **Checkpoint/snapshot:** Periodic state snapshots every 1000 blocks or 1 hour. RocksDB snapshot export/import. Raft log persistence.

5.10.3 Disaster scenarios

Scenario	Detection	Recovery	RTO
Single node failure	Health check $< 30s$	Automatic Raft failover	< 1 minute
Datacenter outage	Monitoring alerts	Promote secondary; restore checkpoint; verify audit chain; resume TSA serial	4 hours
CA key compromise	Per GOYA-PS07-001	Revoke; reconstruct from M-of-N shares; re-issue	24 hours

Scenario	Detection	Recovery	RTO
Data corruption	verify_audit_chain() failure	certificates; emergency CRL Restore last valid checkpoint; replay from peer nodes	4 hours

5.10.4 Testing

- Business continuity plan tested annually via tabletop exercise.
- Failover procedures tested semi-annually with simulated node failure.
- Key ceremony recovery tested annually (reconstruct from custodian shares without using production keys).

5.11 TSP termination

ETSI EN 319 401, clause 7.13

5.11.1 Termination plan

In the event Goya Ledger ceases to provide trust services:

1. **Notification:** Subscribers, relying parties, and the supervisory body notified at least 90 days before termination (or as soon as the decision is made if forced by insolvency).
2. **Certificate revocation:** All outstanding certificates revoked. Final CRL published with nextUpdate set to the maximum validity of any revoked certificate.
3. **OCSP continuity:** OCSP responder continues for at least 90 days after the last certificate expiry, or responsibility transferred to a successor TSP.
4. **TSA continuity:** TSA signing key and token verification information transferred to a successor TSP or archived with a designated custodian.
5. **Audit records:** All audit logs, ceremony records, and certificate records transferred to a successor TSP or to the supervisory body. Minimum 7-year retention obligation survives termination.
6. **Key destruction:** All CA, TSA, and OCSP private keys destroyed per NIST SP 800-88 and HSM vendor zeroization procedures. Destruction witnessed and documented.
7. **Trusted List removal:** Request removal from the national Trusted List (TSL).
8. **Archive:** An archival copy of the complete audit log (hash-chain verified), all issued certificates, all CRLs, the final CPS, and the termination plan itself is retained for the regulatory retention period.

5.11.2 Successor TSP transfer

If a successor TSP assumes responsibility: - The successor must meet the same ETSI EN 319 401 requirements. - All subscriber data, certificates, and audit records transferred securely (encrypted in transit and at rest). - Subscribers notified of the transfer and the successor's identity. - The termination plan submitted to the supervisory body includes the successor's name, OID, and TSL reference.

6. TSP management and operation

6.1 Management responsibility

ETSI EN 319 401, clause 7.1

- **Management commitment:** Senior management formally commits to operating the TSP in accordance with this policy, the CP, the CPS, and applicable legislation. This commitment is documented and signed.
- **Resource allocation:** Management ensures adequate financial, human, and technical resources for continuous operation of all trust services, including HSM maintenance, facility costs, and personnel training.
- **Policy review:** Management reviews this policy and all subordinate policies at least annually, and after any significant incident or organizational change.

6.2 Internal organization

ETSI EN 319 401, clause 7.2

6.2.1 Segregation of duties

The following roles must not be combined in a single individual:

Incompatible role pair	Rationale
Security Officer + PKI Administrator	Policy authority must not overlap with operational key management
RA Officer + PKI Administrator	Identity proofing must be independent of certificate issuance
Auditor + any operational role	Audit independence
System Administrator + PKI Administrator	Infrastructure access must not imply key material access

6.2.2 Trusted roles

All personnel in trusted roles (Security Officer, PKI Administrator, RA Officer) must: - Pass a background check commensurate with the level of access. - Sign a confidentiality and acceptable use agreement. - Complete initial training on PKI operations, this policy, and incident procedures. - Receive annual refresher training (minimum 4 hours, covering policy updates, incident lessons learned, and PQC developments).

Background checks are conducted at hiring and re-screened every 3 years for personnel in trusted roles, or immediately upon role change to a higher-trust position.

6.2.3 Disciplinary process

Policy violations are managed in three tiers:

Tier	Example	Action
Minor	Failure to lock workstation, incomplete log entry	Written warning, mandatory re-training
Serious	Unauthorized access attempt, sharing credentials	Suspension of access, formal investigation, written sanction
Critical	Key material exposure, data breach, deliberate sabotage	Immediate access revocation, termination, incident report per PS07, notification per eIDAS Art. 19(2) if subscriber impact

The Security Officer adjudicates tier classification. Appeals follow the personnel evaluation process in PE01.

6.2.4 Personnel changes

- On appointment: Access provisioned per role definition (section 5.4.1). Training completed before unsupervised access.
- On departure or role change: All access credentials revoked within 24 hours. HSM PINs and shared secrets rotated if the departing individual had access.
- On termination for cause: Immediate revocation of all access. Incident assessment if the individual held a trusted role.

6.3 External organization

ETSI EN 319 401, clause 7.3

6.3.1 Outsourcing

If any component of the trust service is outsourced (e.g., datacenter hosting, HSM management): - The TSP remains fully responsible for compliance with this policy. - The outsourcing agreement must impose equivalent security requirements. - The TSP retains the right to audit the outsourced service. - Outsourced services must be identified in the CPS.

6.3.2 Third-party components

Component	Provider	Assurance
HSM hardware	Thales / Entrust	FIPS 140-3 Level 3 certificate
Datacenter colocation	Tier III provider (Chile)	SLA with 99.95% uptime; physical security audit
NTP time source	Stratum-1 NTP servers	

Component	Provider	Assurance
		Multiple independent sources; <code>NtpTimeSource::validate()</code> with drift detection
Cryptographic libraries	ed25519-dalek, pqcrypto-mldsa, rsa, sha2, hmac	Open source; CAVP/ACVP test vector validation
TLS library	rustls	Memory-safe implementation; no OpenSSL dependency

6.4 Conformity assessment

ETSI EN 319 401, clause 7.1.2

6.4.1 Assessment schedule

- **Initial assessment:** Before the TSP is listed on the Trusted Service List (TSL) or accredited by the Entidad Acreditadora.
- **Periodic assessment:** At least every 24 months, per eIDAS Art. 20(1).
- **Ad hoc assessment:** After any significant change to the trust service infrastructure, algorithms, or organizational structure.

6.4.2 Assessment scope

The conformity assessment covers: - This policy document (ETSI EN 319 401 compliance). - The CP and CPS (ETSI EN 319 411-1/2 compliance). - TSA practices (ETSI EN 319 421 compliance). - Cryptographic controls (ETSI TS 119 312 compliance). - Physical and environmental security. - Personnel and organizational controls. - Incident management and business continuity. - Audit log integrity and retention.

6.4.3 Assessment body

Conformity assessment must be performed by: - An accredited Conformity Assessment Body (CAB) under Regulation (EU) No 765/2008 for EU-scope services. - The Entidad Acreditadora (Subsecretaria de Economia) or its designated auditor for Chilean PSC accreditation.

7. Organizational requirements

7.1 General provisions

ETSI EN 319 401, clause 7.1

Goya Ledger as a TSP shall:

1. Demonstrate the reliability of its operations to subscribers and relying parties.

2. Maintain a documented ISMS (Information Security Management System) aligned with ISO/IEC 27001:2022.
3. Ensure that all trust service operations are performed by appropriately trained personnel in defined trusted roles.
4. Maintain financial resources sufficient to operate the trust service and to cover potential liability from mis-issuance or service failure. This includes professional indemnity insurance as required by Ley 19.799 Art. 14.
5. Publish and maintain an accurate and current CP and CPS, accessible to all subscribers and relying parties.

7.2 Disclosure and notification obligations

Obligation	Regulation	Implementation
Publish CP/CPS	eIDAS Art. 24(2)(h)	API endpoints /policy/cp, /policy/cps; public URL post-accreditation
Inform supervisory body of changes	eIDAS Art. 24(2)(b)	Material changes notified 30 days in advance
Notify security breaches	eIDAS Art. 19(2)	Within 24 hours; procedure in GOYA-PS07-001
Subscriber notification of compromise	eIDAS Art. 24(2)(f)	Immediate for P1; within 24 hours for P2
Publish in Trusted List	eIDAS Art. 22	Upon qualified status; national TSL publication via Entidad Acreditadora

7.3 Record keeping

Record	Retention	Format	Integrity
Audit log (all trust service events)	7 years	JSON, hash-chained	SHA-256 chain; <code>verify_audit_chain()</code>
Issued certificates	7 years after expiry	X.509 DER in RocksDB	Immutable ledger
CRLs	7 years after nextUpdate	DER, RFC 5280	Signed by CA
OCSP responses	7 years	DER	Signed by delegated responder
Time-stamp tokens	7 years	DER, RFC 3161	Signed by TSA
Key ceremony records	Permanent	Video + notarized minutes + digital record	Physical + digital custody
RA identity proofing records	7 years after certificate expiry	Encrypted at rest	Access restricted to RA Officer + Auditor

Record	Retention	Format	Integrity
Incident reports	7 years	Structured document	Version-controlled
Risk assessments	7 years	Structured document	Version-controlled
Conformity assessment reports	7 years	Assessor's report	Signed by CAB

7.4 Legal framework

Jurisdiction	Legislation	Scope
Chile	Ley 19.799	Electronic signatures, certification services, PSC accreditation
Chile	Decreto Supremo No 24	Reglamento de la Ley 19.799
Chile	Decreto Supremo No 181	Technical requirements for accredited PSC
EU	Regulation (EU) No 910/2014 (eIDAS)	Trust services, electronic signatures, mutual recognition
EU	Regulation (EU) 2024/1183 (eIDAS 2.0)	European Digital Identity Wallet, QEAA
International	UNCITRAL Model Law on Electronic Signatures	Cross-border recognition framework

7.5 Data protection and privacy

ETSI EN 319 401, clause 7.10 · GDPR (EU 2016/679) · Ley 19.628 (Chile)

The TSP processes the following categories of personal data:

Data category	Legal basis	Retention	Protection
Subscriber identity (name, email)	Contract performance (GDPR Art. 6(1) (b))	7 years post-certificate expiry	Encrypted at rest (ML-KEM-768 + AES-256-GCM)
National ID / RUT		7 years	Access-controlled, not

Data category	Legal basis	Retention	Protection
	Legal obligation (Ley 19.799 Art. 15)		replicated across nodes
Biometric commitments (SHA-256 hashes)	Explicit consent (GDPR Art. 9(2) (a))	Duration of certificate validity	Only hash commitments stored; raw biometric data never enters the system
Public keys and certificates	Legitimate interest (GDPR Art. 6(1)(f))	7 years post-expiry (archival)	Public by design
Audit logs (access, signing events)	Legal obligation (eIDAS Art. 24(2))	7 years	Append-only, integrity-protected

Data subject rights:

- **Access (Art. 15):** Subscribers may request a copy of their stored personal data via the RA.
- **Rectification (Art. 16):** Identity data corrections require re-verification through the RA process (PO04).
- **Erasure (Art. 17):** Limited by legal retention obligations. Certificates and audit logs cannot be deleted during the 7-year retention period. After expiry, data is destroyed per NIST SP 800-88.
- **Portability (Art. 20):** Subscribers may export their DID, public key, and certificate chain in standard formats (PEM, JWK).

Biometric data (GDPR Art. 9):

The TSP processes biometric data exclusively as SHA-256 commitments for Advanced Electronic Signature (FEA) identity binding. Raw biometric templates (fingerprint, facial recognition, voice) are captured on the subscriber's device, hashed locally, and only the 32-byte commitment is transmitted to the TSP. The TSP never possesses, stores, or processes raw biometric data. Explicit consent is obtained before biometric enrollment.

Data Protection Impact Assessment (DPIA):

A DPIA has been conducted per GDPR Art. 35 and is documented in docs/policy/POLITICA-PRIVACIDAD-EIPD.md. The assessment covers biometric processing, cross-border transfers (Chile-EU), and automated certificate issuance decisions.

Data Protection Officer:

Contact: As defined in the organizational structure. The DPO oversees compliance with GDPR and Ley 19.628 for all subscriber data processing activities.

7.6 Compliance monitoring

Control	Frequency	Method
Audit chain integrity verification	Continuous (on each append) + daily batch	<code>verify_audit_chain()</code>
Cryptographic self-test	Every node startup	<code>run_crypto_self_tests()</code> KAT
NTP time-source validation	Every TSA token issuance	<code>NtpTimeSource::validate()</code> with drift threshold
Access review	Quarterly	Security Officer reviews all role assignments
CRL freshness	Per CP (configurable, typically every 24 hours)	Automated CRL generation and publication
OCSP responder availability	Continuous (health check every 30 seconds)	Monitoring + alerting
Policy document review	Annual	Management review meeting
Penetration test	Annual	External assessor
Business continuity test	Annual (tabletop) + semi-annual (failover drill)	Per GOYA-PS03-001

Appendix A: Mapping to ETSI EN 319 401 clauses

EN 319 401 clause	This document section	Status
5 – General concepts	4	Addressed
6.1 – Terms and definitions	3	Addressed
6.2 – TSP practice statement	5.2	Addressed
6.3 – Risk assessment	5.1	Addressed
7.1 – General provisions	6.1, 7.1	Addressed
7.2 – Internal organization	6.2	Addressed
7.3 – External organization	6.3	Addressed
7.4.1 – Human resources	6.2.2, 6.2.3	Addressed
7.4.2 – Asset management	5.3	Addressed
7.4.3 – Access control	5.4	Addressed
7.4.4 – Cryptographic controls	5.5	Addressed
7.4.5 – Physical and environmental security	5.6	Addressed
7.4.6 – Operations security	5.7	Addressed
7.4.7 – Network security	5.8	Addressed

EN 319 401 clause	This document section	Status
7.4.8 – Incident management	5.9	Addressed
7.4.9 – Business continuity	5.10	Addressed
7.5 – Collection of evidence	7.3	Addressed
7.6 – Compliance	7.5	Addressed
7.7 – TSP service components used by other TSPs	6.3.1	Addressed
7.8 – TSP management	6.1	Addressed
7.9 – Accessibility	5.4.2 (API access)	Addressed. REST API with JSON responses accessible to standard HTTP clients. Web portal accessibility (WCAG 2.1 AA) scoped for future web-based subscriber interface.
7.10 – Other organizational matters	7.4	Addressed
7.11 – Conformity assessment	6.4	Addressed
7.12 – Notification and communication	7.2	Addressed
7.13 – TSP termination	5.11	Addressed

Appendix B: Cross-references to Goya Ledger documents

Document	Document ID	Relationship
Incident Response Plan	GOYA-PS07-001	Section 5.9 detail
Business Continuity Plan	GOYA-PS03-001	Section 5.10 detail
Physical Security Policy	GOYA-SF01-001	Section 5.6 detail
	Per module boundary	Section 5.5 detail

Document	Document ID	Relationship
FIPS 140-3 Cryptographic Module Design		
Electronic Signature Compliance	GOYA-SIG-001	Signature levels, legal alignment (docs/ compliance/ELECTRONIC- SIGNATURE- COMPLIANCE.md)
Encryption at Rest	GOYA-ENC-001	Section 5.3.2 detail (docs/ compliance/ENCRYPTION- AT-REST.md)
Cross-Certification Strategy	GOYA-XCERT-001	Section 6.3.2 (docs/ compliance/CROSS- CERTIFICATION.md)
PSC Certification Roadmap	GOYA-ROAD-001	Operational roadmap (docs/compliance/PSC- CERTIFICATION- ROADMAP.md)
Compliance Framework	GOYA-COMP-001	Control mapping (docs/ compliance/COMPLIANCE- FRAMEWORK.md)
PQC Enterprise	GOYA-PQC-001	Post-quantum migration rationale (docs/ compliance/PQC- ENTERPRISE.md)

Document history

Version	Date	Author	Changes
1.0	2026-08-13	Security Officer	Initial draft Policy document IDs mapped to existing docs. AUP created. Version reference corrected to V3.2.1. GDPR/data protection section added (7.5).
1.1	2026-09-03	Security Officer	Disciplinary process and re-screening added (6.2.3). BSI TR-02102-1 and ANSSI Avis PQC references added. Qualified signature timeline clarified.

Version	Date	Author	Changes
			Status changed to Ready for Review.